Youtube_shots_Maker 코드 리뷰

리뷰 일자: 2026-10-12 | 대상 경로: D:₩WorkSpace₩platform₩Youtube_shots_Maker

> 표기 규칙: 이 폴더의 작업 트리에는 소스가 거의 남아 있지 않다(아래 1장 참고). 그래서 이 리뷰는 두 가지를 근거로 쓴다. - 작업 트리에 실제로 있는 파일: 경로:줄 로 그대로 표기 - 소스가 마지막으로 온전했던 git 스냅샷(5f6d262, 2026-06-08 "first-pull!!") 의 파일: [5f6d262] 경로:줄 로 표기. git show 5f6d262:Youtube_shots_Maker/<경로> 로 확인할 수 있다.

1. 프로젝트 개요

한 줄 설명

"NOMAD Short Factory" — 중국 도우인/샤오홍수 인기 숏폼을 내려받아 Whisper STT -> Claude 대본 각색 -> TTS -> FFmpeg 자막 렌더링을 거쳐 YouTube Shorts/Instagram Reels/TikTok/네이버 블로그에 자동 배포하고, 쿠팡/네이버쇼핑 제휴 링크로 커머스 전환까지 연결하는 멀티테넌트 SaaS ([5f6d262] CLAUDE.md:9-21). 대상은 1인 크리에이터와 쇼핑 리뷰 채널 운영자. 수익 트랙은 A(중드 리컷 광고), B(쇼핑 리뷰 CPS), C(SaaS 구독), D(AI 블로그)의 4개.

현재 폴더 상태 (가장 중요한 사실)

작업 트리는 사실상 "잔해"다.

구분	실제로 남아 있는 것
git 추적 파일 (7개)	todo_list_260530.md, backend/routers/users.py, backend/migrations/002_*.sql, backend/migrations/003_user_roles.sql, components/layout/Header.tsx, components/ui/dropdown-menu.tsx, lib/stores/userStore.ts
추적 안 되는 잔여물	backend/**/__pycache__/*.cpython-314.pyc (core/database/models/routers/services/tasks 전체), backend/.venv, backend/.env, .env.local, .next/, node_modules/(371개 패키지), tsconfig.tsbuildinfo, .claude/settings.local.json
없는 것	package.json, backend/main.py, backend/requirements.txt, core/*.py, services/*.py, tasks/*.py, app/ 전체, CLAUDE.md, README.md

git 이력: 40b6e26(2026-05-27, 전체 구현 Phase 0-6) -> 8b83381(2026-05-28, 디렉토리 삭제) -> 5f6d262(2026-06-08, 109개 파일 재추가 + 수정) -> 0b7f3fa(2026-06-12, 관련 없는 "Floria" 커밋에서 109개 파일, 28,785줄 삭제). 즉 마지막 커밋이 이 프로젝트 소스를 의도치 않게(또는 정리 목적으로) 지우면서 7개 파일만 남겼다. backend/routers/users.py:11-12 는 존재하지 않는 core.auth, database.client 를 import 하므로 현재 작업 트리 상태로는 백엔드도 프론트도 실행되지 않는다.

기술 스택 (5f6d262 기준)

영역	스택	근거
프론트	Next.js 14 App Router, Tailwind + shadcn, Zustand, TanStack Query v5	[5f6d262] CLAUDE.md:44-50
백엔드	FastAPI 0.115 + Uvicorn, Celery 5.4 + Redis	[5f6d262] backend/requirements.txt
DB/인증	Supabase (Postgres, Auth, Storage), service-role 키로 RLS 우회	[5f6d262] backend/database/client.py:1-19
AI	로컬 openai-whisper large-v3, demucs 4.0.1, OpenRouter(anthropic/claude-sonnet-4-5), Anthropic SDK 직접 호출(블로그), Edge-TTS/CLOVA	[5f6d262] backend/services/stt.py:35-47, script_adapter.py:81-82, blog_writer.py:94-122

영역	스택	근거
미디어/크롤링	FFmpeg, yt-dlp, Playwright	[5f6d262] backend/services/video_editor.py, downloader.py
인프라	Vercel(프론트) + Railway(백엔드/Redis), Dockerfile 2종, start.ps1 로컬 기동 스크립트	[5f6d262] railway.toml, vercel.json, start.ps1:62-97

완성도 추정

- 작업 트리 기준: 약 5%. 실행 가능한 코드가 없다.
- git 스냅샷(5f6d262) 기준: 약 55~60%. 백엔드 Python 약 10,000줄(라우터 9개, 서비스 14개, Celery 태스크 5개), 프론트 TS/TSX 약 6,900줄로 기능 골격은 모두 있다. 그러나 todo_list_260530.md:57-95 에 따르면 Anthropic/OpenAI 키, Redis, YouTube/Instagram/TikTok OAuth 가 모두 "미입력/미설정" 상태로 실제 E2E 검증이 된 적이 없고, 네이버쇼핑은 키가 없으면 Mock 으로 폴백한다([5f6d262] backend/services/naver_shopping.py:153-182). 테스트 코드는 0개.

핵심 기능 목록

- 소싱: 도우인/샤오홍수 검색과 다운로드 (yt-dlp + Playwright, downloader.py 798줄)
- 스튜디오: STT -> 음원 분리 -> 대본 각색 -> TTS -> 자막 렌더링 5단계 Celery 파이프라인 ([5f6d262] backend/routers/studio.py:182-300)
- 멀티 계정 관리: 플랫폼 계정 자격증명 AES-256-GCM 암호화 저장, 쿠키 자동 갱신 (account_manager.py 1,146줄)
- 채널 배포: YouTube/Instagram/TikTok OAuth 연결, 예약 배포(5분 주기 beat) ([5f6d262] backend/tasks/workers.py:50-71)
- 블로그(Track D): Claude 로 글 생성 후 Playwright 로 네이버 블로그 자동 게시
- 커머스(Track B): 네이버쇼핑 커넥트 트래킹 URL 생성, 수익 통계

2. 구조 분석

주요 디렉토리/파일과 역할 (5f6d262 기준, 현재 존재 여부 표시)

경로	역할	현재 작업 트리
backend/main.py	FastAPI 앱, CORS, 라우터 9개 등록	없음 (pyc만)
backend/core/auth.py	Supabase JWT 검증, role/plan 기반 권한 의존성	없음 (pyc만)
backend/core/config.py	pydantic-settings, 암호화 키 검증	없음 (pyc만)
backend/database/client.py	service-role Supabase 클라이언트 싱글톤	없음 (pyc만)
backend/routers/*.py	accounts, oauth, sourcing, studio, publisher, proxy, blog, commerce, users	users.py 만 존재
backend/services/*.py	다운로드, STT, 음원분리, 각색, TTS, 렌더링, 배포, 네이버 블로그/쇼핑, 프록시	없음 (pyc만, channel_publisher 는 pyc도 없음)
backend/tasks/*.py	Celery 앱과 4개 파이프라인	없음 (pyc만)
backend/migrations/	002, 003 마이그레이션	존재 (001은 backend/database/migrations/ 에 있었으나 삭제됨)
app/, middleware.ts, lib/api/*	Next.js 페이지, Supabase 세션 미들웨어, API 클라이언트	없음

경로	역할	현재 작업 트리
components/layout/Header.tsx, lib/stores/userStore.ts	헤더와 사용자 스토어	존재 (의존 파일이 없어 고아 상태)
todo_list_260530.md	외부 키/인프라 설정 체크리스트	존재

데이터 흐름 (5f6d262 기준)

Next.js 프론트가 Supabase Auth 로 로그인한 뒤, 액세스 토큰을 Bearer 로 붙여 FastAPI 를 호출한다. FastAPI 는 매 요청마다 service-role 키로 Supabase 클라이언트를 만들어 토큰을 검증하고([5f6d262] backend/core/auth.py:28), 이후 모든 DB 접근은 RLS 를 우회하는 service-role 클라이언트로 수행하며 소유권은 각 라우터의 .eq("user_id", user_id) 로만 보장한다. 무거운 작업(다운로드, STT, demucs, LLM 각색, TTS, FFmpeg 렌더링, 배포)은 Celery 태스크로 발행하고, 프론트는 /task/{task_id} 를 폴링한다. Celery 태스크 내부는 매번 새 이벤트 루프를 만들어 async 서비스를 실행한다([5f6d262] backend/tasks/studio_pipeline.py:41-45). 결과 파일은 Supabase Storage 에 저장된다.

NOMAD Shorts Maker 와의 관계

결론: "백엔드만 분리한 것"이 아니라, 이 프로젝트(1세대, FastAPI + Next.js 14)를 버리고 새로 시작한 후속 제품(2세대)이다. 근거는 다음과 같다.

- 브랜드/개념 계승: 이쪽은 "NOMAD Short Factory"(todo_list_260530.md:1), 저쪽은 "NOMAD AI Factory (ShortsOS)"(NOMAD Shorts Maker/CLAUDE.md:1). 둘 다 STT -> 번역/각색 -> TTS -> 렌더 -> 멀티채널 배포 + 쿠팡 커머스라는 동일한 파이프라인을 다룬다.
- 아키텍처는 완전히 다르다: NOMAD Shorts Maker 는 FastAPI 가 없고 Next.js 16 Route Handlers 52개 + BullMQ(TS 워커) + Python 워커 4개(workers/whisper_worker.py, ffmpeg_worker.py 등)로 구성된다(NOMAD Shorts Maker/PRD.md:655-666, package.json:20-31). Celery, demucs, 네이버 블로그 Playwright, 프록시 풀 같은 이쪽 고유 모듈은 저쪽에 없다.
- 시간 순서: 이쪽 소스 커밋은 2026-05-27~06-08, 저쪽 파일은 2026-06-11 이후 생성. 이쪽 소스가 지워진 커밋(0b7f3fa, 06-12)과 저쪽 착수 시점이 맞물린다.
- 코드 공유 흔적 없음: 저쪽 package.json:2 의 이름은 nomad-content-automator 로, 이 프로젝트가 아니라 또 다른 제품(Content Automator)에서 출발했다.

따라서 Youtube_shots_Maker 는 "보관(아카이브)할지, 유용한 Python 모듈만 NOMAD Shorts Maker 의 Python 워커로 이식할지"를 결정해야 하는 레거시 프로젝트로 보는 것이 맞다.

3. 발견된 문제점

#	심각도	분류	위치(경로:줄)	내용
1	높음	구조	git 0b7f3fa (109 files deleted), backend/routers/users.py:11-12	무관한 커밋에서 소스 109개 파일이 삭제되어 작업 트리에 실행 불가능한 잔해만 남음. 남은 파일은 없는 모듈을 import
2	높음	보안	[5f6d262] backend/routers/oauth.py:76-92, :187	OAuth state 가 서명 없는 base64 JSON. 콜백은 state 안의 user_id 를 그대로 신뢰하고 nonce 검증도 없음. 임의 user_id 로 남의 계정에 내 채널 토큰을 붙이거나 CSRF 로 피해자 계정에 공격자 채널을 연결 가능
3	높음	보안	[5f6d262] app/api/auth/naver/callback/route.ts:54-86	네이버 로그인 시 이메일만으로 기존 Supabase 사용자를 찾아 magic link 를 발급. 다른 경로로 가입한 동일 이메일 계정에 확인 없이 로그인됨(계정 병합/탈취 위험). listUsers() 는 1페이지(기본 50명)만 반환하므로 사용자 50명 초과 시 기존 사용자를 못 찾고 createUser 가 실패

#	심각도	분류	위치(경로:줄)	내용
4	높음	보안	[5f6d262] backend/routers/studio.py:306-340, backend/routers/blog.py:322-349	Celery 태스크 상태 조회가 task_id 소유권을 확인하지 않음. 인증만 되면 타인의 태스크 결과(대본, 파일 경로, 에러 메시지)를 조회 가능
5	중간	보안	[5f6d262] backend/routers/sourcing.py:172-196	DB 에서 내 영상이 아니어도(video_row 가 None) Celery 결과의 file_path 를 그대로 반환
6	중간	보안	[5f6d262] backend/models/script.py:87	각색 요청의 model 필드가 자유 문자열로 OpenRouter 에 그대로 전달됨. 고가 모델 지정으로 비용 남용 가능. 허용 목록 필요
7	중간	보안	[5f6d262] backend/routers/oauth.py:296-299	예외 메시지 원문을 쿼리스트링으로 프론트에 노출(내부 오류/DB 정보 누출)
8	중간	보안	backend/.env, .env.local (작업 트리)	실제 Supabase service key, OpenRouter, Anthropic, OpenAI 키, 암호화 키가 버려진 폴더에 평문으로 남아 있음. git 에는 커밋되지 않았으나(이력 확인) 폴더 공유/백업 시 유출 위험
9	중간	성능	[5f6d262] backend/core/auth.py:28, :41-47, backend/database/client.py:13-19	async def 의존성 안에서 동기 Supabase 호출(create_client, get_user, .execute()) 을 실행해 이벤트 루프를 블로킹. 또 인증 요청마다 Supabase 클라이언트를 새로 생성
10	중간	버그	[5f6d262] backend/services/stt.py:29, backend/tasks/studio_pipeline.py:41-45	모듈 전역 asyncio.Lock 을 태스크마다 새로 만드는 이벤트 루프에서 재사용. 동시 실행 시 "bound to a different event loop" 오류 가능. 또 Whisper large-v3 를 워커 프로세스마다 메모리에 상주
11	중간	버그	[5f6d262] backend/main.py:44-48	allow_origins 에 https://*.vercel.app 와일드카드를 넣었으나 Starlette 는 와일드카드 서브도메인을 지원하지 않음. Vercel 배포 시 CORS 실패. allow_origin_regex 필요
12	중간	구조	[5f6d262] backend/core/auth.py:41-125, backend/migrations/003_user_roles.sql:50-52, components/layout/Header.tsx:53-59	권한 체계가 role(user/basic/pro/admin) 과 plan(free/basic/pro/admin) 두 컬럼으로 이중화. 프론트는 plan, 백엔드 일부는 role 을 봄
13	중간	품질	lib/stores/userStore.ts:14, components/layout/Header.tsx:75	DB 조회 실패나 미설정 시 기본 등급을 admin 으로 표시. UI 표시용이지만 잘못된 기본값으로 권한 오인 유발
14	중간	성능	[5f6d262] backend/services/audio_separator.py:153-171, backend/services/video_editor.py:256-305	demucs/FFmpeg 하위 프로세스에 타임아웃이 없음. 깨진 입력에서 워커가 무한 대기 가능 (Windows 에서 --pool=solo 이므로 워커 전체가 멈춤, start.ps1:97)
15	낮음	품질	[5f6d262] backend/services/account_manager.py (1,146줄), downloader.py (798줄), channel_publisher.py (731줄), app/(dashboard)/settings/page.tsx (1,649줄), publisher/page.tsx (1,360줄)	거대 파일. 특히 설정/배포 페이지는 단일 컴포넌트에 폼, 목록, 모달이 모두 섞임
16	낮음	품질	[5f6d262] backend/services/downloader.py:288-289, :341-342, :428-429, :463-464, channel_publisher.py:172-173 등	except Exception: pass 가 다수. 실패가 조용히 묻힘
17	낮음	품질	[5f6d262] backend/services/blog_writer.py:94-122, script_adapter.py:81-99, geo_metadata.py:19-20	LLM 호출 경로가 Anthropic SDK 직접 호출과 OpenRouter 두 가지로 갈리고 모델명도 claude-sonnet-4-6 / anthropic/claude-sonnet-4-5 로 불일치

#	심각도	분류	위치(경로:줄)	내용
18	낮음	설정	backend/**/__pycache__/*.cpython-314.pyc, 루트 .gitignore	프로젝트 .gitignore 가 함께 삭제되어 루트 gitignore 에 __pycache__ 규칙이 없음. 현재 untracked 상태로 git add . 시 커밋될 위험. pyc 가 Python 3.14 로 빌드되어 문서상 3.11+ 및 openai-whisper 20231117 / demucs 4.0.1 호환성도 불확실
19	낮음	설정	작업 트리 루트	package.json 없이 node_modules(371개), .next, tsconfig.tsbuildinfo 만 남아 있음. 디스크 낭비이며 다른 도구가 Next 프로젝트로 오인
20	낮음	보안	backend/migrations/003_user_roles.sql:58	운영자 이메일을 마이그레이션에 하드코딩해 admin 부여. 환경별 분리 불가, 개인정보가 저장소에 남음
21	낮음	품질	[5f6d262] backend/main.py:75, :83	버전 표기가 0.1.0, 0.3.0, phase 6 으로 제각각
22	낮음	품질	저장소 전체	테스트 0개, CI 없음. 암호화/OAuth/소유권 검증 같은 핵심 로직에 회귀 테스트가 전혀 없음

심각도 높음 상세

#1 소스 유실 (구조) 0b7f3fa 는 메시지가 "feat: Floria Botanic Architecture 웹사이트 구현" 인데 Youtube_shots_Maker 의 109개 파일을 함께 삭제했다. 작업 트리에는 git 추적 파일 7개와 pyc 잔여물만 남아 백엔드, 프론트 모두 실행되지 않는다. 의도한 정리인지 사고인지 먼저 확인해야 하며, 보존할 가치가 있다면 git checkout 5f6d262 -- Youtube_shots_Maker 로 복원하거나 별도 아카이브 브랜치/태그를 만들어야 한다. 그렇지 않으면 다음 정리 작업 때 이력 추적조차 어려워진다.

#2 OAuth state 위조 (보안) _encode_state 는 user_id 를 base64 로 감싸기만 하고 서명하지 않으며, 콜백은 서버 측 저장소에서 state 를 대조하지 않는다. 공격자는 피해자 user_id 를 넣은 state 로 자기 YouTube 계정 OAuth 를 완료해 피해자 계정에 채널을 붙이거나, 반대로 피해자를 유도해 공격자 user_id 로 피해자 채널 토큰을 탈취할 수 있다. HMAC 서명(또는 Redis 에 nonce 저장 후 1회 소비)과 만료 시간이 필요하다.

#3 네이버 로그인 계정 병합 (보안) 네이버가 돌려준 이메일과 같은 이메일을 가진 기존 사용자를 찾아 곧바로 magic link 로 로그인시킨다. 이메일/비밀번호로 가입한 사용자의 계정에 네이버 계정 소유자가 확인 절차 없이 들어오게 되며, 네이버 이메일이 연락처 이메일(검증 수준이 다를 수 있음)인 경우 더 위험하다. 또한 listUsers() 페이지네이션 미처리로 사용자 수가 늘면 로그인이 깨지는 기능 버그도 겸한다. naver_id 기준 매핑 테이블과 명시적 계정 연결 절차로 바꿔야 한다.

#4 태스크 결과 IDOR (보안) /api/studio/task/{task_id} 와 /api/blog/task/{task_id} 는 인증만 확인하고 그 task 가 요청자 소유인지 보지 않는다. Celery 결과에는 각색 대본, 파일 경로, 예외 메시지가 들어 있다. task_id 가 UUID 라 추측은 어렵지만 로그/URL 로 쉽게 노출되는 값이므로, scripts/blog_posts 테이블의 *_task_id 와 user_id 를 함께 조회해 소유권을 검증해야 한다.

4. 효율성 개선 제안

구조/아키텍처

- 먼저 방향을 정한다. (a) 아카이브: 5f6d262 을 태그(archive/youtube-shots-maker-v1)로 남기고 폴더를 삭제, (b) 이식: NOMAD Shorts Maker 의 Python 워커(workers/)로 가치 있는 모듈(demucs 분리, 네이버 블로그 Playwright, 프록시 풀, AES-GCM 자격증명 저장)만 옮긴다. 두 제품을 병행 유지할 근거는 코드상 보이지 않는다.
- 이식하는 경우 FastAPI 라우터는 버리고 순수 서비스 함수만 가져간다. 서비스들이 Supabase 클라이언트를 생성자에서 받는 구조라 이식은 비교적 쉽다.

- 권한은 `plan` 하나로 통일하고, 소유권 검증은 라우터마다 `.eq("user_id")` 를 반복하는 대신 공통 헬퍼(`get_owned_or_404(table, id, user_id)`)로 묶는다.

성능

- 인증 의존성을 동기 함수(`def`)로 바꾸거나 `run_in_threadpool` 로 감싸고, Supabase 클라이언트는 싱글톤을 재사용한다. JWT 는 Supabase JWT secret(또는 JWKS)으로 로컬 검증하면 요청당 외부 왕복이 사라진다.
- Whisper large-v3 는 전용 GPU 워커 큐로 분리하고 `worker_concurrency=1`, 나머지 경량 태스크는 다른 큐로 라우팅한다.
- 모든 하위 프로세스에 타임아웃과 실패 시 프로세스 kill 을 추가한다.

개발 생산성

- 최소한의 pytest 세트: AES-GCM 암복호화 왕복, OAuth state 서명/검증, 소유권 검증 헬퍼, Celery 태스크 상태 매핑.
- LLM 호출을 하나의 클라이언트 모듈로 통합하고 모델명은 설정값 하나에서 읽는다.
- 1,000줄 이상 파일(`account_manager.py`, `settings/page.tsx`, `publisher/page.tsx`)은 플랫폼별/섹션별로 분할.

운영/배포

- 이 폴더의 `.env`, `.env.local` 에 있던 키는 폴더 삭제 전에 사용 여부를 확인하고, NOMAD Shorts Maker 와 공유 중이라면 교체(rotate)를 검토한다.
- 루트 `.gitignore` 에 `__pycache__/`, `*.pyc`, `.venv/` 를 추가해 다른 Python 프로젝트에도 같은 사고가 없도록 한다.
- 정리 커밋과 기능 커밋을 분리하는 규칙을 둔다(#1 재발 방지).

5. 수정 작업 목록 및 권장 모델

#	작업	우선순위	예상 규모	권장 모델	선정 이유
1	`0b7f3fa` 의 삭제가 의도였는지 확인하고, `git tag archive/youtube-shots-maker-v1 5f6d262` 생성 후 유지/폐기/이식 중 방향 결정 문서화	P0	S	Sonnet 5.5	git 명령과 짧은 결정 기록뿐인 단순 작업
2	루트 .gitignore 에 __pycache__/, *.pyc, .venv/, *.tsbuildinfo 추가, 이 폴더의 pyc/.next/node_modules/tsconfig.tsbuildinfo 삭제	P0	S	Sonnet 5.5	설정 파일 정리
3	`backend/.env`, `.env.local` 의 키 목록을 점검하고 다른 프로젝트와 공유 중인 키는 교체한 뒤 파일 삭제	P0	S	Opus 5.5	단순하지만 키를 잘못 지우거나 남기면 운영 장애/유출로 이어짐
4	(유지/이식 시) OAuth state 를 HMAC 서명 + Redis nonce 1회 소비 + 10분 만료로 재구현, 콜백에서 검증	P0	M	Fable 5.1	인증/권한 로직이며 실수 시 계정 탈취
5	(유지/이식 시) 네이버 로그인을 `naver_id` 매핑 테이블 기반으로 바꾸고 이메일 일치 시 자동 병합 대신 명시적 연결 절차 도입, `listUsers` 의존 제거	P0	M	Fable 5.1	인증 흐름 재설계, 계정 병합 정책 판단 필요
6	studio/blog/sourcing 태스크 상태 API 에 task_id 소유권 검증 추가 (scripts.*_task_id, blog_posts, videos.download_task_id 와 user_id 동시 조회), 미일치 시 404	P1	S	Opus 5.5	3개 라우터에 걸친 명확한 수정이지만 보안 영향이 있음
7	`AdaptRequest.model` 을 허용 모델 Enum 으로 제한하고 LLM 호출을 단일 모듈로 통합(모델명 설정화)	P1	M	Opus 5.5	3개 서비스 리팩토링, API 연동
8	인증 의존성 비동기 블로킹 제거: Supabase JWT 로컬 검증으로 교체하고 DB 조회는 스레드풀로 이동	P1	M	Fable 5.1	인증 경로 전체에 영향, 토큰 검증 방식 변경

#	작업	우선순위	예상규모	권장 모델	선정 이유
9	role/plan 이중 권한 체계를 plan 하나로 통합하는 마이그레이션 작성, core/auth.py 와 Header 동기화, 기본값 admin 을 free 로 변경	P1	M	Opus 5.5	데이터 마이그레이션 포함 중간 규모 작업
10	CORS 를 allow_origin_regex=r"https://.*₩.vercel₩.app" + 환경변수 기반 허용 목록으로 변경, OAuth 오류 리다이렉트에서 예외 원문 제거	P1	S	Sonnet 5.5	국소적 설정 수정
11	demucs/FFmpeg 하위 프로세스에 타임아웃과 kill 처리 추가, Celery task_time_limit 설정, STT 전역 Lock 을 프로세스 단위 동기 락으로 교체	P1	M	Opus 5.5	중간 난이도 버그 수정, 여러 서비스 파일
12	(이식 선택 시) demucs 분리, 네이버 블로그 Playwright, 프록시 풀, AES-GCM 자격증명 모듈을 NOMAD Shorts Maker workers/ 로 이식하는 설계와 큐 인터페이스 정의	P2	L	Fable 5.1	두 프로젝트에 걸친 아키텍처 결정
13	account_manager.py(1,146줄)를 암호화/쿠키 갱신/플랫폼별 연결 테스트로 분할, except Exception: pass 를 로깅 포함 처리로 교체	P2	M	Opus 5.5	2~5개 파일 리팩토링
14	settings/page.tsx(1,649줄), publisher/page.tsx(1,360줄)를 섹션 컴포넌트로 분리	P2	M	Sonnet 5.5	반복적 컴포넌트 분할
15	pytest 기본 세트 작성(AES-GCM 왕복, state 서명, 소유권 헬퍼, 태스크 상태 매핑)	P2	M	Opus 5.5	테스트 설계

6. 종합 평가

강점

1. 백엔드 계층 분리가 명확하다. routers / services / tasks / models 로 나뉘고, 서비스가 DB 클라이언트를 주입받아 다른 프로젝트로 이식하기 쉽다.
2. 자격증명 저장을 AES-256-GCM(96비트 랜덤 IV, 키 길이 검증)으로 제대로 구현했다([5f6d262] backend/services/account_manager.py:53-75, backend/core/config.py:59-68). 대부분의 라우터도 .eq("user_id", ...) 로 소유권을 확인한다.
3. 무거운 작업을 모두 Celery 로 넘기고, 블로킹 라이브러리(Whisper, demucs, OpenAI SDK)는 run_in_executor 로 감싸며, 재시도 지연/GPU OOM 시 CPU 폴백 같은 실전 대응이 들어 있다.

약점

1. 현재 작업 트리에는 실행 가능한 코드가 없다. 소스가 무관한 커밋에서 삭제되어 잔해와 비밀키만 남았다.
2. OAuth state 위조, 네이버 로그인 계정 병합, 태스크 결과 IDOR 등 인증/권한 경계가 허술하다.
3. 외부 키와 인프라가 한 번도 연결되지 않은 상태(todo 문서)라 기능 대부분이 미검증이며 테스트가 없다. 권한 체계(role/plan)와 LLM 경로도 이중화되어 있다.

모델별 비율 (15개 작업 기준)

- Fable 5.1: 4개 (27%)
- Opus 5.5: 7개 (47%)
- Sonnet 5.5: 4개 (27%)

권장 진행 순서

1단계 (정리, 반나절): 작업 1~3. 아카이브 태그, gitignore, 잔여물 삭제, 키 점검. 이 단계에서 "폐기" 로 결정되면 여기서 종료한다. 2단계 (보안, 유지/이식 결정 시): 작업 4~6, 8, 10. 인증/권한 경계를 먼저 막는다. 3단계 (품질과

이식): 작업 7, 9, 11~15. 이식이 목적이면 12번을 먼저 하고 나머지는 이식 대상 모듈에만 적용한다.

주 담당 모델

Opus 5.5. 이 프로젝트의 실제 작업량 대부분은 이미 존재하는 코드의 정리, 소유권 검증 추가, 서비스 통합, 테스트 작성처럼 범위가 명확한 중간 규모 작업이다. 다만 OAuth state 재설계, 네이버 로그인 계정 정책, 인증 의존성 교체, NOMAD Shorts Maker 로의 이식 설계 4건은 실수 시 계정 탈취나 두 프로젝트 구조에 영향을 주므로 Fable 5.1 에 맡기고, gitignore/CORS/UI 분할 같은 단순 작업은 Sonnet 5.5 로 비용을 줄인다. 무엇보다 1단계에서 "폐기" 결론이 나면 남는 작업은 Sonnet 수준의 정리뿐이므로, 착수 전에 방향 결정부터 해야 한다.